

Correlation & Detection Engineering

From Logs to Detections

A **single event** is noise. A **correlation** is meaning:

4625 failed logons × 20 from one host in 10 min = possible brute force

Logon success 5 min before bitsadmin.exe beacon = possible ransomware setup

New admin + odd PowerShell + outbound exfil = respond now

Correlation Rule Structure

```
- name: Impossible Travel Detection
  when: any
  of:
    - event.category == authentication
    - and logon from GEO A AND GEO B within 1 hour
  window: 1 hour
  severity: high
  actions: [notify-t2, case-open]
```

Triggers are the **correlation** of *multiple conditions over time*, not single matches.

The Sigma Format (Write Once, Run Anywhere)

Sigma is the open signature language for detection rules. One rule → export to Splunk, Elastic, Sentinel, etc.

```
title: PowerShell Download Cradles
logsource:
  product: windows
  category: process_creation
detection:
```

```
selection:
  Image|endswith: '\powershell.exe'
  CommandLine|contains: ['FromBase64String', 'DownloadString']
condition: selection

level: high
```

Sigma rules are how modern SOC's share detections quickly. You'll read/write/export them.

Detection Engineering Quality Bar

A GREAT rule:

High precision (low FP) – careful selection

High recall – actually catches the thing

Explains itself – references the technique (ATT&CK ID)

Tested – on real data and known samples

Not duplicating – check for overlap with existing rules

The "Known to Unknown" Game

Signature detection: known IOCs (hashes, domains) – brittle, but trivial

Behavioral/technique detection: what the ATTACKER DOES (ATT&CK technique) – survives signature changes

Hunting: assume breach, look for odd-but-not-yet-flagged – you write hypothesis-based queries

The 2020s reality: signature-only detection is dead. Behavior-first, TTP-based detection on top of strong telemetry is the craft.

Alert Naming & the Analyst's Day

Good alert metadata saves the day:

MITRE ATT&CK technique mapping

Affected assets (does it hit a crown jewel?)

Recommended playbook link

Clear severity + a one-liner explanation

A detection that requires reading the source code to understand is a badge of failure. Engineers write *and* maintain – the analyst's Monday morning is the acceptance test.

[← SIEM Fundamentals & Searchin...](#)

[Alert Triage & Incident Handof...](#)